

José Eduardo Gutiérrez Conejo - 2019073558

Bases de Datos II

Lectura 10: Best Practices for Database Security

1. ¿Por qué se deben implementar controles que garanticen “compliance” en bases de datos?
 - **Legalidad y Regulaciones:** Cumplir con regulaciones y leyes es obligatorio en muchos sectores. Por ejemplo, en la industria de la salud, HIPAA impone estrictas regulaciones sobre la protección de datos de pacientes.
 - **Protección de Datos Sensibles:** Las bases de datos a menudo contienen información crítica y confidencial. Garantizar su seguridad es fundamental para prevenir brechas de datos y proteger la privacidad
 - **Reputación y Confianza:** La pérdida de datos o la violación de la privacidad de los usuarios puede dañar seriamente la reputación de una organización y disminuir la confianza de los clientes.
 - **Responsabilidad Empresarial:** Las organizaciones son responsables de proteger la información que poseen. El incumplimiento de este deber puede resultar en sanciones legales y multas.
2. ¿Qué papel juega los sistemas de Observabilidad en garantizar el “compliance” con estándares como HIPAA y PCI DSS? Comente como los controles específicos pueden ser monitoreados con un sistema como Prometheus

La observabilidad mediante estas herramientas permite la supervisión constante de los sistemas y bases de datos para identificar posibles violaciones de políticas de seguridad o intentos de acceso no autorizado. Además pueden configurarse para generar alertas en tiempo real cuando se detectan actividades sospechosas o cuando ciertos umbrales de seguridad se superan. Estos mecanismos también ayudan a mantener registros detallados de todas las actividades de la base de datos, lo que es esencial para la auditoría y la generación de informes de cumplimiento. También permiten el seguimiento de cambios en la configuración de la base de datos, lo que es vital para asegurar que no se realicen cambios no autorizados.

3. ¿Por qué “Separation of Duties” es importante para el manejo de bases de datos? ¿Está bien que una persona tenga control completo sobre todos los sistemas?

Esto es importante ya que evita la concentración de poder en una sola persona, lo que reduce el riesgo de actividades maliciosas o errores accidentales y situaciones en las que una persona podría tener intereses personales o agendas ocultas al tener control total sobre un sistema. Esto es un requisito en muchos marcos de cumplimiento y regulaciones para garantizar un manejo adecuado y transparente además de que fomenta la colaboración y la revisión entre equipos, lo que puede llevar a mejores prácticas y a la identificación temprana de posibles problemas.

4. Tomando en cuenta lo estudiado en clases acerca de seguridad de bases de datos (desde seguridad física hasta aplicación) y este artículo, ¿Que controles consideran que fallaron dando como resultado el faltante de aproximadamente 3200 millones de colones en el Banco nacional? ¿Con lo estudiado en este curso que controles y sistemas implementarían para evitar este tipo de problemas?

<https://delfino.cr/2023/10/banco-nacional-confirma-faltante-de-mas-de-3200-millones-de-colones-de-su-boveda>

Los sistemas que fallaron en detectar los problemas fue que el encargado de verificar que la bóveda tuviese el dinero que tenía que tener, no lo hizo o realizó algún tipo de fraude para ocultar el dinero que debió de haber entrado. Esto podría ser tanto un fallo humano si lo vemos de la forma inocente considerando que nadie se robó el dinero, o se podría ver como un fraude interno donde el manejo de seguridad para este dinero fue afectado y comprometido para realizar este robo.

Basándonos en las prácticas de seguridad de bases de datos, se pueden implementar las siguientes medidas para evitar este tipo de errores o fraudes:

- **Control de Acceso y Autenticación:** Implementar un sistema de autenticación fuerte para garantizar que solo personal autorizado tenga acceso a las áreas donde se manejan efectivo y a los sistemas relacionados.
- **Monitoreo Continuo:** Establecer sistemas de monitoreo en tiempo real para detectar cualquier actividad inusual o sospechosa relacionada con las existencias de efectivo.
- **Separación de Funciones:** Dividir los roles y responsabilidades para asegurarse de que múltiples personas estén involucradas en la administración de efectivo y que haya controles para prevenir posibles manipulaciones.
- **Registro y Auditoría:** Mantener registros detallados de todas las transacciones y actividades relacionadas con las existencias de efectivo, lo que facilita la identificación de cualquier discrepancia.
- **Encriptación de Datos:** Encriptar la información relacionada con las transacciones y el manejo de efectivo para protegerla de accesos no autorizados.
- **Seguridad Física:** Implementar medidas de seguridad física robustas en las áreas donde se almacenan y manejan efectivo, incluyendo sistemas de vigilancia, controles de acceso y medidas de prevención de intrusos.
- **Capacitación del Personal:** Proporcionar formación regular sobre las mejores prácticas de seguridad y los procedimientos específicos para la manipulación y administración de efectivo.
- **Automatización y Tecnología Avanzada:** Utilizar tecnología avanzada, como sistemas de gestión de efectivo automatizados, para reducir la necesidad de manipulación manual y minimizar la posibilidad de errores humanos.
- **Plan de Respuesta a Incidentes:** Tener un plan detallado y actualizado para responder a cualquier discrepancia, incluyendo pasos específicos a seguir y la notificación a las autoridades pertinentes.
- **Revisión y Mejora Continua:** Regularmente revisar y mejorar los controles y procedimientos existentes en función de las lecciones aprendidas y las mejores prácticas de seguridad.